

NIST CSF 2.0

LearnSphere EdTech Cybersecurity Gap Assessment — Complete Scope & Assessment Tables

Document ID	LS-NIST-001	Version	1.0
Assessment Stage	Step 1 · Define Assessment Scope	Assessment Date	07-Sep-2026
Organization	LearnSphere EdTech	Framework	NIST CSF 2.0
Scope Basis	Project 1 ISMS Scope	Assessment Boundary	Cloud LMS ecosystem and supporting security processes

Company / Entity	LearnSphere EdTech
Standard Reference	NIST Cybersecurity Framework (CSF) 2.0; NIST Quick-Start Guide: Creating and Using Organizational Profiles
Related Documents	Project 1 · LearnSphere EdTech ISMS (ISO/IEC 27001:2022 implementation documentation set: ISMS scope, asset register, risk register, Statement of
Document Owner	Chief Information Security Officer (CISO)
Classification	Confidential · Internal Use Only
Version	1.0 · Final
Prepared By	Mr. Meejan Shaikh, GRC Analyst, Information Security Management Team
Reviewed By	Information Security Manager
Approved By	Chief Information Security Officer (CISO)
Assigned Date	10 August 2026
Assessment Date	07 September 2026
Issue Date	10 September 2026

1. Scope Statement

Assessment scope: The NIST CSF 2.0 Gap Assessment covers the LearnSphere EdTech environment supporting its cloud-hosted Learning Management System (LMS), including the AWS production environment, LMS application, databases, identity and access , and relevant third-party providers.

The assessment covers cybersecurity outcomes affecting the confidentiality, integrity, availability and appropriate handling of information processed by these services, with specific attention to student information and the heightened sensitivity of data relating to minors.

This Step 1 document defines the assessment boundary. The detailed Current, Target, Gap and Priority tables are included in the same controlled document for traceability to subsequent NIST CSF 2.0 assessment and remediation stages.

2. Organizational Context

Area	Scope Definition
Organization	LearnSphere EdTech is an India-based EdTech organization providing a cloud-hosted LMS for schools.
Technology model	Cloud-hosted environment primarily operated on AWS, supported by application, database, IAM, source-code, CI/CD, backup, monitoring and endpoint technologies.
Users	Students, teachers, school administrators and employees; the assessment gives specific consideration to student users and minors' information.
Information	entity/access information, application and operational information, source code, backups and security logs.
Security context	The assessment addresses confidentiality, integrity and availability risks, privacy-related requirements, access governance, data lifecycle, monitoring, incident response and recovery.

3. In-Scope Environment and Boundaries

Boundary	Included in Assessment	Scope Relevance
Cloud / Infrastructure	AWS production environment, configurations, supporting cloud services and infrastructure controls.	Availability, configuration, access and infrastructure security.
Application	LearnSphere LMS application and associated development/deployment processes.	Application security, secure development, vulnerabilities and data handling.
Data / Databases	Production databases, student records, academic records and backup/recovery repositories.	Confidentiality, integrity, retention, minimization and recovery.
Identity & Access	IAM, user accounts, privileged accounts, authentication and access permissions.	Least privilege, access review, JML and privileged access.
Development	Source-code repositories, CI/CD pipelines and related development assets.	Code access, change integrity and secure development.
Monitoring	Security monitoring/SIEM and relevant alerting and logging capabilities.	Detection, investigation, correlation and response evidence.
Endpoints / People	Employee laptops and personnel involved in information-security-relevant processes.	Endpoint protection, access, awareness and operational responsibilities.

Boundary	Included in Assessment	Scope Relevance
Third Parties	Relevant cloud and service providers supporting in-scope services.	Supplier risk, contractual requirements and monitoring expectations.

4. Information and Data Scope

Information Category	Included	Primary Assessment Focus
Student personal information	Yes	Privacy, consent, minimization, access and lifecycle.
Assessment / academic records	Yes	Integrity, access restriction, monitoring and recovery.
Teacher / staff information	Yes	Access, privacy and lifecycle protection.
Identity and access information	Yes	Authentication, authorization and privileged access.
Source code / CI-CD information	Yes	Source-code access, secure development and change control.
Backup / recovery information	Yes	Backup protection, recovery readiness and retention.
Security logs / monitoring data	Yes	Detection, investigation and evidence.

5. In-Scope Processes and Activities

Process / Activity	Scope Coverage	Reason for Inclusion
Student data collection and processing	In Scope	Determines whether cybersecurity and privacy requirements are embedded in processing activities.
Identity lifecycle / access management	In Scope	Critical to student-record access, least privilege and privileged account governance.
Application development and change	In Scope	Changes may alter security controls or student-data processing.
Security monitoring and alert handling	In Scope	Supports detection and investigation of unauthorized activity.
Incident response	In Scope	Required for events affecting student or children's data.
Backup, recovery and continuity	In Scope	Supports availability and recovery of critical services and data.
Third-party service management	In Scope	External dependencies can introduce cybersecurity and privacy risk.

6. NIST CSF 2.0 Tier Categorization

Tiers characterize the rigor of cybersecurity risk governance and management. They are separate from the internal 0–4 maturity score.

Function	Current Tier	Target Tier	Tier Category	Assessment Rationale
Govern	Tier 1	Tier 3	Partial → Repeatable	Governance requirements for privacy, children’s data, parental consent, minimization and accountability are present but not consistently formalized or integrated.
Identify	Tier 1	Tier 3	Partial → Repeatable	Data, technology and risk information is available in parts of the environment, but authoritative inventories and data-processing risk triggers are incomplete.
Protect	Tier 1	Tier 3	Partial → Repeatable	Access, authentication, data lifecycle and protection practices exist, but student-record access governance requires consistent least privilege, review and enforcement.
Detect	Tier 1	Tier 3	Partial → Repeatable	Monitoring and alerting capabilities exist, but coverage measurement, third-party monitoring and correlation of IAM/application/student-record events are not consistently defined.
Respond	Tier 2	Tier 3	Risk Informed → Repeatable	Incident response practices are risk-informed and operational, but children’s-data severity, evidence handling, communications and dedicated playbooks need consistent definition.
Recover	Tier 1	Tier 3	Partial → Repeatable	Recovery capabilities exist, but scenario-based testing, dependency documentation and systematic conversion of lessons learned into improvements require formalization.

Tier scale

Tier 1 · Partial	Tier 2 · Risk Informed	Tier 3 · Repeatable	Tier 4 · Adaptive
Ad hoc and reactive risk management.	Risk awareness exists but is not consistently organization-wide.	Formalized and repeatable risk management practices.	Adaptive practices informed by lessons learned and predictive indicators.

7. Detailed Gap Analysis

Gap = Target – Current. The Current/Target values use the project’s internal 0–4 assessment scale. Priority reflects business, regulatory, privacy and security significance.

NIST Function	Category / Subcategory	Current	Target	Gap	Priority
Govern	GV.OC-03	1	3	2	High
Govern	GV.RM-01	2	3	1	High
Govern	GV.RR-02	2	3	1	High
Govern	GV.PO-01	2	3	1	High
Identify	ID.AM-02	2	3	1	High
Identify	ID.AM-07	1	3	2	High
Identify	ID.RA-04	2	3	1	High
Identify	ID.RA-05	2	3	1	High
Protect	PR.AA-05	2	4	2	Critical
Protect	PR.AA-03	2	3	1	High
Protect	PR.DS-01	2	3	1	High
Protect	PR.DS-10	1	3	2	High
Detect	DE.CM-01	2	3	1	High
Detect	DE.CM-06	2	3	1	High
Detect	DE.AE-02	2	3	1	High
Detect	DE.AE-04	1	3	2	High
Respond	RS.MA-01	2	3	1	Medium-High
Respond	RS.AN-03	2	3	1	Medium-High
Respond	RS.CO-02	2	3	1	Medium-High
Respond	RS.MI-01	2	3	1	Medium-High
Recover	RC.RP-01	2	3	1	Medium
Recover	RC.RP-03	2	3	1	Medium
Recover	RC.CO-02	2	3	1	Medium
Recover	RC.IM-01	1	3	2	Medium

8. Function-Level Summary

Function	Current	Target	Gap	Priority
Govern	1.75	3.00	1.25	High
Identify	1.75	3.00	1.25	High
Protect	1.75	3.25	1.50	Critical
Detect	1.75	3.00	1.25	High
Respond	2.00	3.00	1.00	Medium-High
Recover	1.75	3.00	1.25	Medium
Overall	1.79	3.04	1.25	—

9. Out-of-Scope Boundaries

Boundary	Treatment
Unrelated personal / non-business systems	Excluded unless connected to or materially affecting an in-scope service.
Unrelated third-party environments	Excluded where they have no role in processing, hosting, supporting or protecting in-scope services/data.
Non-cybersecurity business activities	Excluded where they do not influence the defined cybersecurity scope or information flows.

10. Scope Acceptance & Approval

Management approval confirms that the organizational, technology, information, people, process and third-party boundaries represent the intended LearnSphere EdTech assessment boundary. Material changes should trigger a documented scope review.

Role	Name	Signature	Date
Prepared By	Mr. Meejan Shaikh – GRC Analyst	_____	07-Sep-2026
Reviewed By	Information Security Manager	_____	07-Sep-2026
Approved By	CISO	_____	07-Sep-2026

Step 1 output: an approved assessment boundary with the Tier categorization and Current / Target / Gap / Priority tables retained for end-to-end traceability.